

Here's your task

As a Cyber Security professional, you've been asked to review an organization and complete a detailed Risk Report of your findings.

Client Overview

RetailNova Pty Ltd is a retail company headquartered in Melbourne, Australia. Founded in 2012, the company has grown to employ approximately 1,200 staff and generates an annual revenue of \$450 million. RetailNova sells consumer electronics, home appliances, and lifestyle products through both physical stores and a robust e-commerce platform.

The company's digital infrastructure includes a custom-built e-commerce website and mobile application, integrated with payment gateways PayPal, and Afterpay. RetailNova uses cloud-connected point-of-sale systems across its 85 stores nationwide. Customer relationship management is handled through Salesforce, while SAP is used for enterprise resource planning, covering inventory, finance, and HR. The company relies on AWS for hosting and it integrates with third-party services for logistics, marketing, and loyalty programs.

RetailNova collects and stores a variety of customer data, including personal information such as names, emails, phone numbers, and addresses. It also retains tokenized payment details, purchase history, behavioral analytics, and loyalty program data.

Employee access to systems is managed through role-based access control (RBAC). Corporate staff are allowed to use their own devices under a BYOD policy and access internal systems remotely via VPN. Internal communication is facilitated through Microsoft Teams and Slack.

RetailNova has experienced several cybersecurity incidents in recent years. In 2023, a phishing attack targeted customer service representative, resulting in credential compromise. In 2024, a ransomware attempt was thwarted by endpoint protection, though it caused a two-hour downtime. In 2025, a data leak from a third-party marketing vendor exposed the email addresses of 5,000 customers.

The company has implemented basic security awareness training for its staff and uses firewalls and antivirus software.

Threat and Vulnerability Identification Template

Use this template to identify key assets, associated threats, potential vulnerabilities, and initial ideas for mitigation. This exercise helps build foundational skills in cybersecurity risk assessment.

Asset Name	Asset Description	Associated Threats	Potential Vulnerabilities	Mitigation Notes
AWS cloud Infrastructure	Databases, application, and storage systems.	Unauthorized access, ransomware, & misconfigurations.	Weak IAM polices, Misconfiguring cloud resources, insufficient logging & monitoring.	Apply least-privilege IAM, enable AWS security tools, and continuous cloud monitoring (CloudTrail & Guard Duty)
Employee Devices (BYOD)	Employees personal laptops and Mobile devices used by employees to remotely access company systems through VPN.	Malware infection, unauthorized access, lost or stolen device, regulatory & compliance violations, & data leakage.	Unsecured personal device, insecure WI-FI access, weak password, lack of device encryption, & lack of remote wipe/lock capability.	Apply MDM, full-disk encryption, enable remote wipe/screen lock, install endpoint protections, & enforce MFA & string password policies.
third-party Vendor's and Services.	External vendors supporting logistic, loyalty programs, payment processing, and other services that integrated with RetailNova systems.	Data leaks, supply chain attacks, unauthorized access, & third-party compromise.	Shared credentials, Excessive data sharing, weak vendor security control, delayed patching and software updates, insufficient employee security awareness training, & dependence in single vendor.	Restrict data sharing, conduct vendor security assessments, apply least privilege access, require MFA, implement multi-vendor strategy, & develop business continuity & disaster recovery plans.

Risk Criteria

The below explains what each item in the Risk Assessment means.

Criteria	Description
Risk Description	Detailed explanation of the scenario, what could go wrong, and why it matters.
Assets at Risk	The information, system, or service impacted (e.g. customer data, VDI environment).
Threat	Who or what could cause the risk (e.g., insider, cybercriminal, accident, malware). The action or event (e.g., data exfiltration, privilege misuse, physical theft).
Vulnerability	Weakness – the gap or condition that enables the threat (e.g., extended idle session, clipboard sharing).
Existing Controls	Current safeguards in place (e.g., MFA, logging, endpoint DLP).
Inherent Risk Rating	Risk level before any mitigations are applied.
Residual Risk Rating	Risk level after current controls are considered.
Likelihood	The probability of occurrence (e.g., Rare, Possible, Likely).
Consequence	Severity – level of damage if realised (e.g., Minor, Moderate, Major, Extreme).
Rating	The outcome of the risk likelihood and consequence evaluation.
Mitigations	Treatment Plan – actions to reduce, transfer, avoid, or accept the risk.
Risk Owner	Person or role accountable for managing the risk (e.g., the person who uses the software)

Risk Assessment

Complete this assessment for at least 3 risks.

Risk Details			
Risk ID	Risk-01	Date Identified	15/05/2026
Risk Title	AWS Cloud Infrastructure Data Breach and System Outage	Review Date	17/05/2026
Risk Identification:			
Risk Description	RetailNova relies heavily on AWS cloud infrastructure to host its e-commerce platform, databases, applications, and storage systems. Weak IAM policies, cloud misconfigurations, or insufficient logging and monitoring could allow unauthorized access to sensitive customer and business data. A successful attack may also disrupt online services, resulting in downtime, financial losses, reputational damage, and possible non-compliance with the Australian Privacy Act.		
Assets at Risk	AWS-hosted databases, e-commerce platform, customer data, business applications, ERP integrations, cloud storage systems, online sales operations.		
Threat	External cybercriminals, ransomware operators, malicious insiders, unauthorized access attempts, cloud account compromise, service disruption attacks.		
Vulnerability	Weak IAM configurations, excessive privileges, insufficient monitoring/logging, insecure cloud resource configuration, lack of continuous cloud security assessment.		
Existing Controls	RBAC access management, firewalls, antivirus software, endpoint protection, basic security awareness training, AWS hosting environment.		
Inherent Risk Analysis			
Likelihood	Consequence	Inherent Risk Rating	
Likely	Extreme	High	
Residual Risk Analysis			
Likelihood	Consequence	Residual Risk Rating	
Possible	Major	Medium	
Risk Treatment			
Mitigations	Implement least-privilege IAM policies, enable AWS CloudTrail and GuardDuty monitoring, conduct regular cloud security audits and penetration testing, apply multi-factor authentication (MFA), enable automated configuration compliance checks, implement backup and disaster recovery procedures, and improve incident response readiness.		
Risk Monitoring and Review			
Risk Owner	Chief Information Security Officer (CISO) / Cloud Infrastructure Manager		

Risk Details			
Risk ID	Risk-02	Date Identified	15/05/2026
Risk Title	Employee BYOD Device Compromise and Unauthorized Remote Access	Review Date	17/05/2026
Risk Identification			
Risk Description	RetailNova permits employees to use personal laptops and mobile devices under a BYOD policy to access internal systems remotely through VPN connections. Unsecured personal devices, weak passwords, malware infections, or insecure Wi-Fi networks may allow attackers to gain unauthorized access to corporate systems and sensitive data. This could result in data leakage, credential theft, malware spread, or compliance violations.		
Assets at Risk	Employee accounts, VPN infrastructure, customer information, internal communication platforms (Microsoft Teams and Slack), SAP systems, Salesforce CRM, corporate network resources.		
Threat	Cybercriminals, phishing attackers, malware infections, credential theft, device theft/loss, insecure remote access.		
Vulnerability	Unsecured personal devices, weak passwords, lack of device encryption, unpatched operating systems, insecure home/public Wi-Fi usage, limited BYOD monitoring.		
Existing Controls	VPN access, RBAC permissions, endpoint protection, antivirus software, basic security awareness training, firewalls.		
Inherent Risk Analysis			
Likelihood	Consequence	Inherent Risk Rating	
Likely	Major	High	
Residual Risk Analysis			
Likelihood	Consequence	Residual Risk Rating	
Possible	Moderate	Medium	
Risk Treatment			
Mitigations	Implement Mobile Device Management (MDM), enforce MFA for VPN access, require full-disk encryption, implement remote wipe capability, enforce strong password policies, require endpoint detection and response (EDR), restrict access from non-compliant devices, and provide advanced phishing awareness training.		
Risk Monitoring and Review			
Risk Owner	IT Security Manager / Endpoint Security Administrator		

Risk Details			
Risk ID	Risk-03	Date Identified	15/05/2026
Risk Title	Third-Party Vendor Data Leak and Supply Chain Security Risk	Review Date	17/05/2026
Risk Identification			
Risk Description	RetailNova integrates with third-party vendors for logistics, payment processing, marketing, and loyalty programs. Weak vendor security controls or shared credential misuse could lead to unauthorized access or exposure of customer information. The company already experienced a third-party marketing vendor data leak in 2025 affecting 5,000 customer email addresses, demonstrating an existing supply chain security risk. A major vendor breach could lead to financial penalties, reputational damage, operational disruption, and customer trust loss.		

Assets at Risk	Customer personal information, loyalty program data, payment processing systems, marketing databases, integrated APIs, supply chain systems, business reputation.	
Threat	Third-party compromise, insider threats at vendors, cybercriminals targeting supply chains, credential theft, unauthorized API access, vendor system breaches.	
Vulnerability	Shared credentials, insufficient vendor risk assessments, weak vendor access controls, delayed security patching, excessive data sharing, dependency on external providers.	
Existing Controls	Vendor contracts, RBAC controls, tokenized payment data, firewalls, antivirus software, basic awareness training, third-party integrations management.	
Inherent Risk Analysis		
Likelihood	Consequence	Inherent Risk Rating
Likely	Extreme	High
Residual Risk Analysis		
Likelihood	Consequence	Residual Risk Rating
Possible	Major	Medium
Risk Treatment		
Mitigations	Conduct regular vendor security assessments, implement vendor risk management framework, enforce least-privilege third-party access, require MFA for vendors, establish security requirements in contracts, monitor third-party access logs, implement incident response coordination with vendors, and reduce unnecessary customer data sharing.	
Risk Monitoring and Review		

Risk Owner	Vendor Risk Manager / Chief Information Security Officer (CISO)
-------------------	---

To	Person Person Person
Cc	Person
Bcc	Person
Subject	

Cybersecurity Risk Prioritisation Matrix

Understanding the Likelihood Rating

The table below provides the categories and ratings for likelihood:

Likelihood Ratings	Description	Criteria
Rare (1)	Exceptional circumstances only	May occur only in very unusual situations
Unlikely (2)	Possible, but not expected	Could happen but not typical; requires specific conditions (e.g. targeted phishing bypassing all filters).
Possible (3)	Might occur at some point	Has occurred in similar organisations; realistic but not frequent (e.g. ransomware attempt on enterprise endpoint).
Likely (4)	Will probably occur in most circumstances	Expected to happen periodically (e.g. phishing emails, credential stuffing attempts).
Almost Certain (5)	Expected to occur frequently	Has occurred multiple times, highly predictable (e.g. malware probes, daily scanning activity).

Understanding the Consequence Ratings Table

The table below provides the categories and ratings for impacts:

Consequence Rating	Description	Criteria
Insignificant (1)	Negligible impact	No compromise of sensitive data, no disruption, minimal financial or reputational impact.
Minor (2)	Small impact	Limited operational disruption; minimal data exposure (non-sensitive data); easily contained.
Moderate (3)	Noticeable impact	Partial service disruption; limited sensitive data exposure; moderate cost or compliance breach.
Major (4)	Severe impact	Significant outage of critical systems; large-scale sensitive data breach; regulatory non-compliance with penalties.
Extreme (5)	Catastrophic impact	Extended enterprise-wide outage; compromise of PROTECTED/SECRET data; severe financial/reputational damage; possible criminal or regulatory prosecution.

The 5x5 Risk Matrix

Use this 5x5 risk matrix to evaluate and prioritise cybersecurity risks. For each identified risk, assess its likelihood (1 = Rare, 5 = Almost Certain) and impact (1 = Insignificant, 5 = Critical). Plot the risk in the matrix and use the result to guide mitigation priorities.

Risk Levels

Likelihood ↓ Impact →	Insignificant (1)	Minor (2)	Moderate (3)	Major (4)	Extreme (5)
5 – Almost Certain	MEDIUM	HIGH	HIGH	EXTREME	EXTREME
4 – Likely	MEDIUM	MEDIUM	HIGH	Risk-02	Risk-01, Risk-03
3 – Possible	LOW	MEDIUM	MEDIUM	HIGH	HIGH
2 – Unlikely	LOW	LOW	MEDIUM	MEDIUM	HIGH
1 – Rare	LOW	LOW	LOW	MEDIUM	MEDIUM

- **Low** – Acceptable; manage by routine controls and monitoring.
- **Medium** – Requires management attention; additional controls may be needed.

- **High** – Significant; must be treated with priority, monitored closely, and escalated to senior management.
- **Extreme** – Unacceptable; immediate executive-level attention and remediation required.

Tips for Completing the Matrix

- Start by identifying the risk scenario (e.g., data breach, system outage).
- Assign a likelihood score based on how often this type of risk occurs.
- Assign an impact score based on potential damage to operations, reputation, or finances.
- Use the matrix to prioritise: risks in the top-right corner (high likelihood and impact) need urgent attention.